

SE – LAB 1

NAME : VIKAS R

SRN : PES1UG24AM477

SEC: H

PROBLEM STATEMENT : 13- Patient Health Record Consent Management System

Req ID	Type	Description	Priority	Acceptance Criteria	Rationale
FR-001	Functional	The system shall allow patients to grant time-bounded (e.g., 24-hour) access permissions for specific diagnostic records to verified clinic doctors.	High	Pass: Clinic access automatically revokes upon expiry timestamp. Fail: Clinic accesses records after consent expiration.	Core functionality enabling patient-centric, secure data sharing.

FR-002	Functional	The system shall allow a patient to manually revoke any active consent permission before the scheduled expiration time.	High	Pass: A doctor's request to access records returns an immediate 403 Forbidden error upon revocation. Fail: Doctor continues to view records after manual revocation.	Enforces patient autonomy and immediate control over sensitive medical records.
FR-003	Functional	The system shall allow clinic administrators to verify and approve registered medical staff credentials before granting them access to request patient records.	Medium	Pass: Unverified medical staff cannot initiate consent requests or receive access. Fail: Unverified practitioner accesses patient data.	Protects patient privacy by preventing fraudulent or unaccredited access.

FR-004	Functional	The system shall provide patients with an active consent dashboard displaying the real-time status (Active, Expired, Revoked) of all permission grants.	Medium	Pass: Dashboard updates within 1 second of any status change showing correct timestamps. Fail: Revoked or expired grants remain marked as active on the dashboard.	Provides transparency and full visibility to patients over their data lifecycle.
FR-005	Functional	The system shall enforce granular categorization filters, allowing patients to select specific record types (e.g., Blood Reports, Imaging) to share while excluding others.	High	Pass: A doctor granted access to Lab Reports receives an access denied error when attempting to fetch Cardiology reports. Fail: All record types are exposed regardless of selected categories.	Prevents over-exposure of sensitive and unrelated medical history.

NFR-001	Non-Functional (Security & Audit)	All consent grant, revoke, and access events shall be permanently written to an append-only audit trail.	High	Pass: Benchmarking tests confirm target latency and security standards under simulated peak load with zero log mutability. Fail: Any consent event fails to generate an immutable log entry.	Guarantees non-repudiation and strict compliance with health data privacy regulations.
NFR-002	Non-Functional (Performance)	The system shall validate consent authorization tokens and return an access decision in under 200 ms under a concurrent load of 1,000 requests.	High	Pass: 95th percentile response latency is $\leq 200 \text{ ms}$ under simulated load testing. Fail: Response latency exceeds 200 ms or the authorization gateway times out.	Ensures healthcare professionals can access time-critical patient data without latency bottlenecks.

SE – LAB 1

NAME : VIKAS R

SRN : PES1UG24AM477

SEC: H

PROBLEM STATEMENT : 13- Patient Health Record Consent Management System

Use-Case Specification: Grant Granular Consent

Document Version: 1.0

Use Case ID: UC-01

Use Case Name: Grant Granular Consent

Primary Actor: Patient

Secondary Actor / Service: Consulting Doctor / Diagnostic Clinic, Audit Logger

1. Brief Description

Enables an authenticated patient to select a verified healthcare practitioner or clinic, specify granular access permissions for specific diagnostic records, set a time-bound validity window, and issue a cryptographically verifiable access token.

2. Preconditions

1. The Patient is successfully authenticated and logged into the Patient Health Record portal.
2. The target Consulting Doctor or Clinic has been verified and registered by the Clinic Administrator.
3. The Patient has valid medical records/diagnostic reports stored in the system gateway.

3. Postconditions

- **Success (Guaranteed):**
 - A time-bounded consent token with granular record scopes is generated and active.
 - An immutable audit record detailing the grant event (Patient ID, Doctor ID, scope, timestamps) is permanently committed to the audit trail.
 - The patient's consent management dashboard is updated in real time.

- **Failure:**
 - No access token is issued, no data access permissions are altered, and the
 - **8a1.** Append-only audit logger encounters a connection timeout or write failure.
 - **8a2.** System halts token generation immediately to prevent unlogged access grants (Fail-Secure policy).
 - **8a3.** System rolls back the transaction and displays: *"Authorization failed due to system security check. Please try again."*
 - **8a4.** Use case terminates in a failure state.
 - error state is recorded in system logs.

4. Main Success Scenario (MSS)

1. Patient navigates to the **Consent Management** module and selects **"Grant New Consent"**.
2. System fetches and displays a searchable directory of verified clinics and consulting doctors.
3. Patient searches for and selects the intended consulting doctor.
4. System displays the patient's categorized medical record types (e.g., Blood Panel, Radiology/MRI, Prescription History).
5. Patient selects the specific record categories to share (excluding all unselected records).
6. Patient defines the access duration window (e.g., standard default 24 hours or custom duration).
7. Patient reviews the consent summary and clicks **"Authorize Access"**.
8. System executes **UC-06: Log Audit Trail** to write the complete transaction to the append-only log.
9. System generates an authorized, time-bounded JWT/consent token mapped to the doctor's credentials.
10. System displays a confirmation receipt: *"Consent successfully granted until [Expiry Timestamp]"* and redirects the patient to the active dashboard.
11. Use case ends successfully.

5. Alternate Flows

- **3a. Selected Doctor/Clinic Is Suspended or Unverified:**
 - **3a1.** System checks provider verification status and finds it inactive or revoked by the Clinic Admin.
 - **3a2.** System displays an error alert: *"The selected provider's credentials are not currently verified. Access cannot be granted."*
 - **3a3.** Patient selects an alternative verified doctor or cancels the operation.
 - **3a4.** Flow resumes at Step 3 or terminates.
- **6a. Invalid Custom Duration Window:**
 - **6a1.** Patient inputs an expiration timestamp in the past or exceeds the maximum allowable duration (e.g., > 30 days).

- **6a2.** System triggers an inline validation alert: *"Invalid duration. Consent window must be between 1 hour and 30 days."*
- **6a3.** Patient corrects the duration.
- **6a4.** Flow resumes at Step 7.
- **8a. Audit Log Service Failure:**

